Examen 1 — Analyse d'un incident

3 novembre 2026 · François Paquin, CISSP

Consignes

Vous disposez de 3 heures pour analyser un seul incident et répondre aux trois parties. L'examen compte pour 100 points.

Partie	Sujet	Points
A	Réseau et capture	20
B	Analyse du pcap dans Wireshark	45
C	Interprétation de l'incident	35

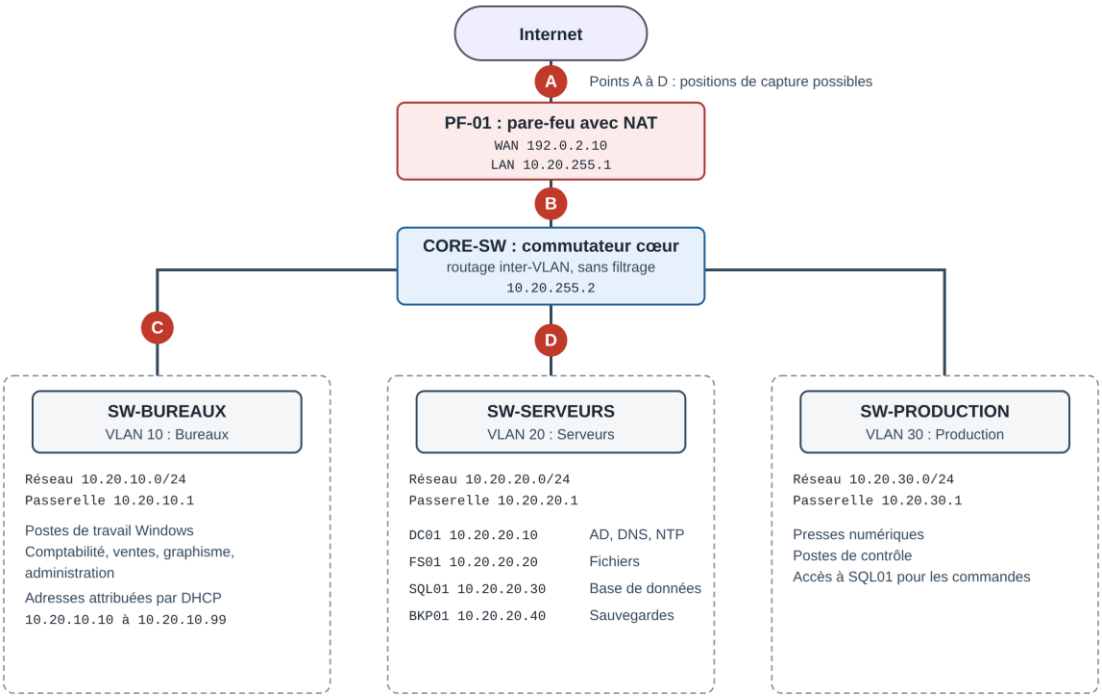
- **Fichier fourni :** `examen1_incident.pcap`. Wireshark suffit pour toute la partie B.
- **Ordre :** répondez dans l'ordre qui vous convient. La partie C peut se faire sans avoir terminé la partie B.
- **Matériel permis :** vos notes, vos labos, l'aide-mémoire à la fin de cet énoncé et la documentation en ligne. L'IA générative n'est pas permise, conformément au plan de cours.
- **Justifications :** une réponse sans preuve tirée du pcap ou du scénario ne donne pas tous les points. Vous pouvez inclure des captures d'écran.
- **Fuseau horaire :** les heures de l'examen sont en UTC. Dans Wireshark : *View > Time Display Format > UTC Date and Time of Day*.
- **Remise :** déposez vos réponses sur la plateforme du cours avant la fin de la période.

Mise en situation

Vous êtes analyste de sécurité pour l'Imprimerie Pontiac-Nord, une PME fictive de 60 employés. Le mardi 27 octobre 2026, le pare-feu a signalé un transfert sortant inhabituel vers Internet.

Par chance, un capteur temporaire installé pour diagnostiquer un problème de performance enregistrait déjà le trafic d'un lien du réseau. Personne n'a noté lequel. Il a produit `examen1_incident.pcap`, qui couvre environ 14 minutes à partir de 13 h 42 UTC.

Votre gestionnaire vous demande de reconstituer l'incident à partir de cette capture et de la carte du réseau ci-dessous.



Le commutateur cœur route le trafic entre les VLAN sans aucun filtrage. Les liens C et D sont des liens *trunk*. Le pare-feu applique la NAT à tout le trafic sortant.

Partie A : réseau et capture (20 points)

A1. Où se trouvait le capteur? (8 points)

Déterminez la position (A, B, C ou D) où le pcap a été capturé (2 points). Pour chacune des trois autres positions, donnez une raison tirée du pcap qui l'élimine (2 points chacune).

Position du capteur : _____

Position éliminée	Raison tirée du pcap

A2. Port miroir et tap (6 points)

Ces questions sont indépendantes du pcap (2 points par question).

1. Outre la perte de paquets, quel effet la surveillance de plusieurs ports par un seul port SPAN peut-elle avoir sur l'ordre et les horodatages des paquets? Expliquez pourquoi.
2. Quelle méthode utiliseriez-vous pour capturer le trafic dans les prochaines minutes sans interrompre la connexion réseau? Pourquoi?

3. Qu'entend-on par « agrégation » dans un tap? Quels en sont les risques pour la capture?

A3. Angle mort (3 points)

Deux postes du VLAN 10 échangent des fichiers directement. Ce trafic apparaîtrait-il à la position que vous avez choisie en A1? Expliquez pourquoi et indiquez où vous configureriez la capture pour le voir.

A4. Capacité du capteur (3 points)

Le lien de la position C est en *full duplex* à 1 Gb/s. À l'heure de pointe, il transporte 700 Mb/s dans chaque sens. On le copie sur un port miroir de 1 Gb/s. Que risque-t-il d'arriver à la capture, et quelle solution proposez-vous?

Partie B : analyse du pcap dans Wireshark (45 points)

Pour chaque question, indiquez le filtre ou la fonction de Wireshark utilisé, et le numéro d'un paquet qui prouve votre réponse.

B1. Hôte compromis (8 points)

La capture contient plusieurs postes. Identifiez celui qui a été compromis (2 points par information).

Information	Réponse	Paquet ou filtre
Adresse IP		
Adresse MAC		
Nom d'hôte		
Compte de l'utilisateur		

B2. Téléchargement initial (5 points)

Donnez le domaine contacté, l'adresse IP du serveur et l'URL complète du fichier téléchargé par ce poste.

B3. Fichier malveillant (8 points)

Extrayez le fichier du pcap. Il est inerte : il ne contient aucun code exécutable.

1. Donnez son nom (1 point) et son empreinte SHA-256 (3 points).
2. Comparez le type annoncé dans la réponse HTTP et le type réel du fichier. Appuyez-vous sur ses premiers octets (2 points).
3. Expliquez pourquoi ce fichier correspond à la définition d'un cheval de Troie (2 points).

B4. Serveur de commande et de contrôle (9 points)

1. Donnez le domaine et l'adresse IP du C2 (2 points).
2. Mesurez l'intervalle moyen entre les requêtes du *beacon* et sa variation (2 points).

3. Donnez deux indices, autres que l'intervalle, montrant qu'il ne s'agit pas d'un logiciel légitime (2 points).
4. Un autre hôte de la capture produit aussi du trafic très régulier. Identifiez ce trafic et expliquez pourquoi il n'est pas un *beacon* malveillant (3 points).

B5. Reconnaissance interne (10 points)

1. À quelle heure UTC, à la seconde près, le poste reçoit-il l'ordre de balayer le réseau? Citez le contenu de cet ordre (2 points).
2. De quel type de balayage de ports s'agit-il? Prouvez-le avec la séquence de drapeaux TCP observée sur un port ouvert (3 points).
3. Combien d'hôtes actifs le balayage découvre-t-il dans le VLAN 20? Donnez leurs adresses IP (2 points).
4. Quel port ouvert révèle le service de base de données de SQL01? De quel service s'agit-il (2 points)?
5. Que fait le poste envers ce service après le balayage? Donnez l'heure UTC et le protocole observé (1 point).

B6. Indicateurs de compromis (5 points)

Dressez une liste de cinq IOC de types différents, utiles pour chercher cette menace sur les autres postes. L'adresse IP et le nom du poste compromis ne comptent pas.

Type d'IOC	Valeur

Partie C : interprétation de l'incident (35 points)

Cette partie repose sur le résumé ci-dessous. Vous pouvez y répondre sans les résultats de la partie B.

Résumé de l'enquête. Une employée de la comptabilité a reçu le courriel reproduit en C1 et a cliqué sur le lien. Elle a ensuite lancé le fichier téléchargé, qui se présentait comme une facture PDF. L'analyse de son poste a révélé une clé de registre *Run* ajoutée pour relancer le programme à chaque ouverture de session.

Le poste a ensuite contacté un serveur externe à intervalle régulier. Sur ordre de ce serveur, il a balayé le VLAN 20 et s'est connecté au serveur de base de données, qui contient les coordonnées et l'historique de commandes des clients. Les données ont ensuite quitté l'entreprise.

C1. Courriel d'hameçonnage (6 points)

Relevez trois indices précis d'hameçonnage dans ce courriel (2 points par indice). Le vrai site du fournisseur est `www.papeterie-laurentienne.example`.

> ***De :*** *Facturation Papeterie Laurentienne (`facturation@papeterie-laurentiene.example`)*
>
> ***Répondre à :*** `comptes.recevables.2026@courriel-gratuit.example`
>
> ***À :*** `comptabilite@imprimeriepontiacnord.example`
>
> ***Objet :*** *URGENT : facture 2026-1187 impayée, suspension du compte sous 24 h*
>
> ***Authentication-Results :*** *spf=fail, dkim=none, dmarc=fail*
>
> *Bonjour,*
>
> *Malgré nos rappels, votre facture 2026-1187 demeure impayée. Sans règlement aujourd'hui, nous suspendrons vos livraisons de papier.*
>
> *Consultez la facture ici :* ***[Voir la facture PDF]***
>
> *Ne transférez pas ce message et n'appelez pas notre service à la clientèle, qui n'a pas accès à ce dossier.*
>
> *Note de l'analyste : le lien mène à un domaine sans rapport avec le fournisseur.*

C2. Cyber Kill Chain (7 points)

Associez chaque fait à sa phase. Utilisez chaque phase une seule fois : Reconnaissance, Weaponization, Delivery, Exploitation, Installation, Command and Control, Actions on Objectives.

Fait	Phase
Le poste interroge régulièrement un serveur externe pour recevoir des ordres.	

Fait	Phase
L'attaquant découvre que l'imprimerie achète son papier à la Papeterie Laurentienne.	
Les données des clients sont copiées hors de l'entreprise.	
L'attaquant emballe son programme dans un faux fichier de facture.	
Une clé de registre *Run* assure le retour du programme à chaque session.	
Le courriel contenant le lien arrive dans la boîte de l'employée.	
Le lancement du fichier fait exécuter le code de l'attaquant sur le poste.	

C3. MITRE ATT&CK (6 points)

Pour chaque observation, choisissez la technique et la tactique dans les listes suivantes (1 point par ligne). Certaines techniques ne servent pas.

- **Tactiques :** Initial Access, Execution, Stealth (Defense Evasion dans les versions antérieures à la v19), Discovery, Command and Control, Exfiltration.
- **Techniques :** T1021.002 SMB/Windows Admin Shares, T1036.007 Double File Extension, T1041 Exfiltration Over C2 Channel, T1046 Network Service Discovery, T1071.001 Web Protocols, T1110 Brute Force, T1204.002 Malicious File, T1566.002 Spearphishing Link, T1595 Active Scanning.

Observation	Technique	Tactique
Le courriel ciblé contient un lien vers un fichier.		
L'employée lance elle-même le fichier.		
Le nom du fichier se termine par `.pdf.exe`.		
Le poste dialogue avec son C2 au moyen de requêtes HTTP.		
Le poste balaie les services du VLAN 20 depuis l'intérieur.		
Les données partent vers le serveur qui donne les ordres.		

C4. Triade CID et risque (5 points)

1. Quelle propriété de la triade CID l'incident touche-t-il directement? Quelle autre propriété serait touchée si l'attaquant avait chiffré SQL01 (2 points)?
2. Pour le risque lié à SQL01, nommez une menace, une vulnérabilité et un impact tirés du scénario (3 points).

C5. Défense en profondeur (6 points)

1. Proposez une règle de segmentation entre le VLAN 10 et le VLAN 20 qui aurait limité ce balayage et la connexion à SQL01. Précisez où l'appliquer sur cette carte et ce qui resterait permis (3 points).
2. Proposez deux autres mesures, à des couches différentes. Associez chacune à une fonction du NIST CSF 2.0 (3 points).

C6. Lecture de flux (5 points)

CORE-SW exporte des flux IPFIX unidirectionnels. Voici un extrait de la même journée, après la fin du pcap. Les adresses sont remplacées par des étiquettes pour ne pas révéler les réponses de la partie B.

Début (UTC)	Durée	Proto	Source	Destination	Paquets	Octets
14:11:05	00:02:14	TCP	POSTE-X:52144	SQL01:1433	9 120	612 Ko
14:11:05	00:02:14	TCP	SQL01:1433	POSTE-X:52144	33 480	46,8 Mo
14:14:32	00:03:41	TCP	POSTE-X:52160	EXTERNE:443	33 910	47,1 Mo
14:14:32	00:03:41	TCP	EXTERNE:443	POSTE-X:52160	8 870	588 Ko
14:15:12	00:00:01	TCP	POSTE-Y:53112	FS01:445	42	8,1 Ko

1. Qu'est-ce que ces flux indiquent, dans l'ordre? Appuyez-vous sur le sens et le volume des octets (3 points).
2. Quelle information le pcap aurait-il pu ajouter sur la connexion à SQL01, et pourquoi conserve-t-on quand même les flux plus longtemps que les pcap (2 points)?

Fin de l’examen 😊

Aide-mémoire Wireshark

Cet aide-mémoire couvre les filtres et les fonctions utiles à l'examen. Aucune expression régulière n'est nécessaire.

Besoin	Filtre d'affichage
Trafic d'une adresse IP	`ip.addr == 10.0.0.5`
Trafic d'un sous-réseau	`ip.addr == 10.0.0.0/24`
Trafic d'une adresse MAC	`eth.addr == aa:bb:cc:dd:ee:ff`
Numéro de VLAN	`vlan.id == 100`
Nom d'hôte dans DHCP	`dhcp.option.hostname`
Comptes Kerberos (un compte en $ est un compte machine)	`kerberos.CNameString`
Requêtes DNS	`dns.flags.response == 0`
Requêtes HTTP	`http.request`
Requêtes POST	`http.request.method == "POST"`
Nom de site dans TLS	`tls.handshake.extensions_server_name`
Connexions amorcées (SYN)	`tcp.flags.syn == 1 and tcp.flags.ack == 0`
Réponses SYN/ACK	`tcp.flags.syn == 1 and tcp.flags.ack == 1`
Paquets RST	`tcp.flags.reset == 1`
Réponses d'écho ICMP	`icmp.type == 0`
Trafic NTP	`ntp`

Besoin	Fonction
Afficher l'heure UTC	*View > Time Display Format > UTC Date and Time of Day*
Mesurer l'écart entre les paquets filtrés	*View > Time Display Format > Seconds Since Previous Displayed Packet*
Ajouter un champ comme colonne	Clic droit sur le champ > *Apply as Column*
Voir les échanges par hôte	*Statistics > Conversations* ou *Endpoints*
Voir les protocoles présents	*Statistics > Protocol Hierarchy*

Besoin	Fonction
Lire une conversation	Clic droit sur le paquet > *Follow > HTTP Stream* ou *TCP Stream*
Extraire un fichier	*File > Export Objects > HTTP*

Pour examiner un fichier extrait :

Action	Linux	Windows PowerShell
Empreinte SHA-256	`sha256sum fichier`	`Get-FileHash fichier -Algorithm SHA256`
Premiers octets	`hexdump -C fichier | head -5`	`Format-Hex fichier | Select-Object -First 5`

En NIST CSF 2.0, les six fonctions sont : Gouverner, Identifier, Protéger, Détecter, Répondre et Rétablir.